Cyber: Governance of the Security Supply Chain

BGIN Block 15 · Georgetown University Capitol Campus, 111 Massachusetts Avenue NW, Washington, D.C.

Date	15 October 2026
Room	Room A (2424)
Published time	15:40–17:10
Workstream	security-supply-chain
Status	Draft for working-group review. Source: closed captions.
Rule	Chatham House Rule. Information may be used without revealing the identity or affiliation of speakers or other participants, directly or indirectly.

This is a session record, not a transcript. Substantive discussion is retained with uncertainty and disagreement made explicit. Reported claims are not verified findings. Candidate agreements require working-group confirmation before use as decisions. Actions omit personal owners and identifying roles.

Agreements

The following sentences stand on their own. These are candidate agreements and reported points of convergence for working-group review. Inclusion does not establish consensus, verify a technical claim, or record formal adoption. The working group must confirm each decision before it is cited as such. Claims that were only discussed, including figures and alternatives that were not adopted, remain in full under Discussion.

The session is the cybersecurity working group's supply-chain document, started at Block 13, with Block 14 (March this year) as the last presentation point.

May 2024 DMM (external vendor, key management, about $300 million, DPRK attribution as briefed by police and FBI) remains the trigger story for the original two-party contract problem.

The next written step is a short living list of potential supply-chain risks, updated periodically, not a single heavy volume. Scope need not be frozen now. Draft from the JFSA April document. Review at the next Block (top of 2027). Discuss layers and pathways before then, including offline.

Hardware distribution tampering is in scope as a different supply-chain type from the vendor-staff cases. Lifecycle education and formal verification of wallet software were accepted as document inputs.

The JFSA briefing's three pillars (firm supervisory guideline and wallet-provider notification; JVCEA rules and audit plus the crypto ISAC; the public report, exercises, and budgeted penetration tests) are the policy picture the list should be able to point at.

AI-integrated attacks and software 0-days should be in a later edition if capacity allows.

Business meeting follows immediately (17:10). No further supply-chain decision was taken in that handoff.

Documents considered

The session referred to the following documents, repositories, and standards. Bibliographic identifications and factual checks added during review are marked as editorial clarifications; they do not imply that the links were spoken or that the meeting adopted the findings. Names of the people who introduced the material are omitted.

Editorial source check: the June 2026 research paper identifies Safe{Wallet} and the compromised development/UI path in the Bybit case (pp. 34–35). This supplements the oral exchange, which left the third-party implementation uncertain.

Submitted session decks: Governance of the Security Supply Chain, slides 5, 7 and 9 (https://bgin-global.org/documents/block-events/block15/CS/Block15_Supply_Chain_Intro.pdf); Crypto Asset Cybersecurity, slides 5, 7, 9, 11 and 13 (https://bgin-global.org/documents/block-events/block15/CS/Crypto_Asset_Cybersecurity_Sugino_JFSA.pdf). These clarify caption terms; their claims are not new meeting agreements.

April 2026 JFSA policy and the separate June 2026 research paper Cybersecurity Issues and Countermeasures in Crypto-Asset-Related Businesses. The research paper enumerates ten cases; the submitted JFSA deck presents five: Bybit, Euler Finance, Resolv, Kelp DAO/LayerZero, and Litecoin. Source: https://bgin-global.org/documents/block-events/block15/CS/ResearchPaper_dtc_20260630_en.pdf.

BGIN supply-chain document trail: Block 13 audit-framework items and threat-response knowledge base; Block 14 (March this year) framework presentation. Version label unverified.

Forthcoming JFSA supervisory guideline under the amended FIEA; wallet-service-provider notification regime. Neither is published text yet.

JVCEA cybersecurity-rule and audit discussion; Japan crypto ISAC.

Incident-response exercise scenarios (Bybit, Bitget, and similar) and a budgeted JFSA penetration-test program.

Amended Financial Instruments and Exchange Act (passed a few months before the meeting). Payment Services Act still the current crypto framework, with the policy shift toward investment-product treatment.

No Discourse thread, Proof of Control page, or KYA-OS page was discussed in this slice. No posters.

Discussion

The following is the substance of the session. It preserves claims, figures, alternatives, and objections. Discussion does not establish a decision. Any candidate agreement requires explicit working-group confirmation.

Workstream: security-supply-chain, inside the cybersecurity working group. The last minutes are repeated at the start of `d1_business`.

The session covered the background to the work, hardware-wallet risks, and cybersecurity guidance. Zoom participation was treated as the remote half of the session.

Plan as stated: background on why the document exists; the JFSA cybersecurity publication of April this year; new cases from the prior week (distribution-channel tampering); then extra perspectives to put in the BGIN document.

Why the document exists The workstream started at Block 13, over about the last two years, on security of the supply chain. The trigger given was May 2024: DMM Bitcoin, a Japanese exchange, was attacked in the key-management / custody system. The compromise was at an external technology vendor, not inside the exchange and not inside Japan. The problem as stated was a contract between two different kinds of organization, and a regulatory perimeter that did not cover the vendor.

Incident line as briefed, before the JFSA slides:

2014, Japan: mentioned, not described.

2018, Coincheck, Japan: exchange hot-wallet compromise. [unverified side label: "Megal link."].

Around 2020: targets shifted to protocols and bridges, described as a new single point of failure, with partners inside the code and cross-chain dependencies as the target.

May 2024: DMM, the document trigger.

A similar methodology was discussed in connection with Bybit and the October hardware-wallet incident. The written research paper dates the Bybit attack to February 2025 (p. 34); the precise October incident date still needs its disclosure.

A different supply-chain type, individual hardware wallets, was placed in the prior week.

Lesson drawn from DMM, as described in the discussion: a LinkedIn recruiter and a fake pre-employment test against an employee; cookies and access into a vendor's unencrypted communications; a transaction request manipulated; about $300 million lost. Japanese police and the FBI were said to have framed the attack as mounted by North Korea. The vendor sat outside the perimeter and could still influence transactions. Social engineering of vendor staff was called a key-management risk. The operator must verify what is signed, not only who the contract is with. A contract was said not to equal control of the vendor. Signing keys were described as the hoped-for hard point in the ecosystem and as sitting outside the regulatory perimeter: the operator is held accountable, there may be no contract that actually covers the failure, and insurance is then unclear.

What the working group had already put on paper:

After 2024, built on a Japanese financial-sector security framework, including vendors and configuration. Presented at Block 14; a version label in the caption ("E") is unverified.

Block 13: on the order of thirty audit-framework items, plus a shared threat-response knowledge base.

Block 14, March this year: existing framework presented, with a mapping at least to [unverified: "Csmo"] and an inventory.

Last year's substance included what contracts with external firms cover, and how corporate responsibility is split. An appendix and a checklist were described as not enough for a national-security model.

The JFSA April paper was introduced by title, as policy on strengthening crypto-asset exchange service providers, with a deep look at responsibility between organizations.

Hardware wallets, prior week Floor: tampering is not one region. A European distributor saw the same exploit as the Southeast Asian channel. The devices are consumer hardware wallets (Ledger was the product under discussion).

Case as briefed, clarified against introduction slide 7: Ledger devices sold through the Malaysia-based reseller CryptoBilis reportedly contained a covert LTE/eSIM implant that read the 24-word recovery phrase from the screen and transmitted it over the mobile network. Genuine-device checks cannot see the added input. There is no logical check of that external hardware. Modified units were also bought on Amazon Japan and Yahoo Auctions. The same report was attributed to Singapore and Germany. Editorial source check: the submitted introduction deck (slide 7) reports losses of over US$86 million across hundreds of wallets, with the investigation ongoing. This resolves the caption's unit and magnitude; it is a reported slide figure, not an independently verified final loss total.

Industry response as briefed, clarified against introduction slide 7: Ledger halted distributor sales in Southeast Asia and Hong Kong; MediaMarkt suspended Ledger sales in Europe on 13 October; Trezor was reducing its reseller network from 1 January 2027; OneKey revoked the reseller. These remain claims reported in the submitted deck, whose incident account is marked investigation ongoing. No perfect solution was claimed. The open operational question was how to get a reliable warning to customers.

Floor additions, offered for this document:

Ledger had released another hardware wallet that day or recently.

At an Ethereum event the prior week, the lifecycle point was that a hardware wallet had been assumed to last forever. It will not, especially if larger signatures (caption: "Eq signatures") need more RAM. Lifecycle education and recommendations were proposed for the BGIN document.

Formal verification of wallet software, tied to a security target or protection profile, so a verifier can check the code. Described as something the Ledger team had said it was interested in.

A customer-side check that does not require opening the device: if a formal check can run on the user's machine when the device is plugged in.

A credit-card contrast was used: a new card activated by a QR code is a single, replaceable step in the lifecycle. Hardware is hard to replace, so the design has to include user verification and distributor or provider validation. That discussion was paused for the JFSA briefing.

National versus industrial security, in answer to a floor question: the duty in the first instance is the company's duty to customers. The attacker, in the cases discussed, has nation-level capability (North Korea was named; Chinese actors were also mentioned, with a caution about naming countries). From the state's point of view it can be a national-security problem. The gap is between a firm's limited responsibility and the countermeasures a state expects. The room's conclusion was that the

supply-chain problem has to be defined again in that context, including where the attack is coming from. The contract-and-checklist work from last year was explicitly called insufficient as a national-security model.

A software-implementation security session was flagged for the next day (a list or gold-standard for implementations). The point made in advance: certification of the product at the factory does not survive a bad module inserted in distribution, and ordinary customers cannot see the module.

JFSA briefing (Zoom) Scope of the April report: cybersecurity for crypto-asset service providers and others, including centralized exchanges and DeFi, plus JFSA's policy approach.

Regulatory context: crypto assets are still under the Payment Services Act, but are now treated as investment products. The amended Financial Instruments and Exchange Act was passed a few months ago. The stated reason to tighten cybersecurity is the incident pattern, especially social engineering, not only theft of private keys.

Three pillars:

1. Firm-level. JFSA already monitors each regulated entity's posture. It will update the supervisory guideline under the FIEA. Drafting is underway; industry communication soon; public comment aimed at the beginning of next year. A notification regime will cover wallet service providers used by regulated crypto businesses in Japan. It was called probably unique. Who is inside the regime is still under discussion, with publication aimed at the same window. One sentence in the caption said "beginning of this year"; the operative statement was the beginning of next year.

2. Mutual support. The self-regulatory body JVCEA is being encouraged to strengthen its own rules and to be able to audit. Its cybersecurity committee has started on how to write the rules and how to build audit capability. Japan's crypto ISAC already exists; the push is for regulated entities to share more threat and vulnerability information through it.

3. Public support. The April policy and the separate June research paper on domestic and overseas attacks were discussed. JFSA is supporting incident-response exercises with scenarios based on recent cases, including Bybit and Bitget. Penetration tests of some regulated Japanese exchanges will be run with JFSA budget and were described as needing to start soon.

Ecosystem map (supply-chain risk called increasing):

Wallet service provider: a primary vector. The Bybit incident was described as starting in a third-party wallet provider's system. The exchange's own environment was described as not the origin. A trading platform's own operations can still fail independently. Hardware in that stack includes HSMs and hardware wallets. The current Ledger cases were said to belong in that hardware supply-chain risk.

Supervisory-guideline direction, still being considered and not yet a rule: if an exchange uses hardware wallets, retail units sold on the open market (Amazon Japan was the example) may not be acceptable. Enterprise hardware and software wallets sold directly (Ledger was the example of a firm that sells both retail and enterprise) were described as the more plausible channel. Mitigation of that supply-chain

risk "might" become a requirement.

On-chain protocols and DeFi: code vulnerabilities, and vulnerabilities in the chain itself. An XRP Ledger 0-day, detected months ago and believed already fixed, was the example. Code-security assurance was called essential.

Cross-chain protocols: code plus the sequencer and messaging path that is supposed to keep transaction details intact across chains.

Node operations: RPC and node-infrastructure providers, messaging, and oracles. The Kelp DAO / LayerZero case concerns bridge-verification infrastructure; the written paper treats these labels as one case, distinct from Litecoin.

Validators, sequencers, and protocol developers operating on that infrastructure.

Issuers and smart-contract operations: a bad operation or a contract bug can mint unbacked stablecoins or tokens.

Stablecoin gap, stated as a gap: many places already regulate exchanges and have some cybersecurity expectations. Japan has stablecoin legislation and does not have specific cybersecurity requirements for issuers. Missing examples given: assurance that the contract has no vulnerability; limits on issuance and redemption. The same absence was claimed for other jurisdictions, not only Japan. Hong Kong's stablecoin regime might already include issuer cybersecurity requirements; that is not, as briefed, an international standard. The gap was offered as one BGIN could fill. JFSA was described as considering issuer cybersecurity requirements, with a regulatory discussion expected soon.

CEX attack-vector slide: shown and skipped as familiar.

Bybit lessons the briefing wanted kept:

Checking amount and destination, and avoiding blind signing, is not enough.

In the manipulated transactions, destination was a smart-contract address (Safe was named) and was not what changed. The fund was supposed to go to a smart contract. Call data called another contract. Signers needed to read call data, not only destination and amount.

Open question: can exchange operators who sign actually read call data?

Bybit's account, as relayed: the Ledger used to sign did not show that information; call data was not on the device screen.

Reading all call data was called genuinely hard.

JFSA is considering stating, in the supervisory guideline, which risks apply when an exchange interacts with a smart contract.

Euler Finance: cited as a DeFi case caused by a smart-contract bug. Details skipped.

Resolv Protocol (identified in the submitted research paper, p. 32): crypto-backed stablecoin. Social engineering of an external developer who still had cloud credentials; attacker obtained signing authority on the stablecoin contract and minted a large amount; swaps out through several exchanges (venue names garbled). Operational security and how signing authority was held were the failures. A PYUSD

incident at Paxos about one and a half to two years ago was cited as an internal operational failure of a large issuer, to argue the same class of problem is not limited to small DeFi teams. Question put: why are there still no cybersecurity requirements for stablecoin issuers, especially if trust banks, other financial institutions, and payment firms start issuing?

Kelp DAO / LayerZero cross-chain case (identified in the submitted research paper, p. 32):

Tokens burned on one chain are minted on another. Nodes check integrity and carry a message.

Unauthorized access to node infrastructure; some nodes could approve or forge a message; remaining honest nodes were DDoS'd and could not reject it.

A forged message minted on Ethereum even though nothing valid had happened on the source chain.

The minted asset was then deposited as DeFi collateral; borrowing and liquidations followed; the briefing called that credit risk across DeFi and a financial-stability issue.

International discussion was described as almost absent. The same point was said to have been raised at BGIN about a year and a half ago and to be still open.

Financial institutions and asset managers are entering DeFi and collaborating with protocols (Uniswap and others were named). Public-chain activity still carries this credit risk. The briefing asked for international discussion from a financial-stability standpoint.

The written research paper groups Kelp DAO / LayerZero as one infrastructure/bridge-verification case. It treats Litecoin's reorganization and cross-chain payout as a separate case. This resolves the names without merging the two incidents.

Litecoin case:

A logic flaw the developers were already trying to fix. Node operators were asked to upgrade. Updated and non-updated nodes both existed.

Unpatched miners extended an invalid chain by 13 blocks (editorially corrected against JFSA slide 13); updated nodes rejected it. Before reorganization, an attacker put a malicious transaction into those 13 blocks.

A cross-chain message paid out bitcoin. After the Litecoin reorganization, the Litecoin-side deposit disappeared.

Causes named: chain code, cross-chain operations, and exploitation of reorganization.

The briefing said five examples were presented and ten were analyzed, in research dated to this June. From ISAC conversations: state-level attackers are shifting. Social engineering was the common method from about two years ago through a few months ago, and it still happens, but there is a significant move toward 0-days in software that DeFi and exchanges use. Bybit was given as the 0-day example: the third-party software that led into the operational system is still not identified; the briefing's belief was that it started from a software vulnerability and not from social engineering, unlike the older pattern. JFSA and the ISAC were both described as needing to keep up. Recommendations on the last slide were called high-level and already familiar; they were not read out.

After the briefing A periodic update of this research was requested. New supply-chain types since the paper: the distribution channel for hardware, and AI or agent systems as a new attack surface. The discussion noted that the paper needs updating to cover AI-integrated attacks and software zero-days. Capacity, and help from companies, was acknowledged as the constraint. An update was offered, subject to capacity.

The workstream was restated. It began as the DMM question: the relationship between two companies. After the briefing, the risk list is wider. Proposal: do not maintain one heavy document; publish a short, somewhat abstract list of potential supply-chain risks; refresh it periodically; add a perspective each year. First step is the list of risks that are caused by the supply chain. Connect it to offline discussion. Between now and the next Block, discuss the list of layers and pathways. Scope does not have to be finalized in the room. A first document can be published as that list, with drafting consolidated from the JFSA document, and a review draft brought to the session at the next Block, described as the top of 2027. No questions or objections were voiced. The session closed and the business meeting was set for three minutes later, at 17:10.

Matters not resolved

No dispute was recorded on the "living list" plan. Silence was taken as consent to proceed. Scope itself was explicitly not closed.

Retail hardware wallets versus enterprise channel: JFSA is considering a supervisory expectation and has not set it.

Who falls under the wallet-service-provider notification regime.

Stablecoin issuers: no specific cybersecurity requirements in Japan (contract assurance, mint and redeem limits). Claimed for other jurisdictions too. Hong Kong may differ. Not an international standard. Offered as a BGIN gap, not as a drafted text.

Call-data visibility: Ledger screens did not show the Bybit call data; whether signers can or should parse call data is open. JFSA may clarify exchange-to-contract risk in the guideline.

Cross-chain forged messages that become DeFi collateral and then credit losses: raised at BGIN ~18 months ago, still barely discussed internationally.

Firm duty versus nation-level attackers. Last year's contract checklist was called not enough for a national-security model. Insurance without a contract that covers the vendor is open.

No complete technical fix for distribution-channel implants. Customer warning, lifecycle education, and on-device or on-host formal verification were proposals.

Genuine-device check cannot see added hardware, as briefed.

Attack shift from social engineering to 0-days: the Bybit third-party software was still unnamed. This sits in tension with the earlier DMM incident account, which was social engineering of a vendor. They were different cases; the caption also muddles dates.

Kelp DAO / LayerZero is one case in the written paper; Litecoin is separate. The introduction deck reports over US$86 million in hardware-wallet losses, with the investigation ongoing; this is not a

verified final total.

The Bybit date is February 2025 in the written research paper. Introduction slide 7 dates the reported MediaMarkt suspension to 13 October; this is a response date, not a single date for the entire hardware-wallet incident.

Capacity to revise the JFSA-linked paper, and what company help would be appropriate.

AI and agents as a supply-chain surface: agreed it belongs in an update; no content yet.

Disposition of the work

Active BGIN document since Block 13. Block 13 produced audit-framework material and a threat-response knowledge base. Block 14 (March this year) presented the framework and a mapping. The JFSA April cybersecurity policy and separate June research paper are the external anchors. This session did not adopt text. It widened the outline from "contract between exchange and vendor" to a list of layers: wallet providers, retail hardware, HSMs, chain and DeFi code, cross-chain messaging, RPC and oracles, validator and sequencer operations, and stablecoin issuance. A first public list plus a 2027 review draft is the committed shape. The JFSA guideline update, the notification regime, and issuer cybersecurity requirements are JFSA processes, not BGIN decisions; BGIN's offered role is the gap on issuer cybersecurity and the living risk list.

Actions

Each action is written so that it can be tracked without the rest of the record. Where the room named only a person, the action is kept and the name is omitted.

Draft a concise list of potential supply-chain risks, consolidated from the JFSA document, without waiting for a final scope.

Before the next Block, identify the layers and pathways, including in the offline discussion. Add one new perspective a year rather than growing one heavy text.

Bring a review draft to the next Block session, described as the top of 2027.

Include the hardware-wallet distribution cases, lifecycle limits, and formal-verification checks as candidate sections.

Ask whether the JFSA analysis can be revised on a cycle, with company help if needed, covering AI-linked attacks and 0-days.

Next day: software-implementation security session (certification does not cover post-factory tampering).

Watch, but do not pre-empt: FIEA supervisory-guideline public comment (target beginning of next year); wallet-provider notification scope; possible issuer cybersecurity requirements; JFSA penetration tests starting soon.

Coverage

This record covers the published supply-chain session in Room A at 15:40–17:10. The recording has a gap after the AI session before this discussion begins. Figures are reported session claims, not independently validated measurements. Technical names are corrected where supported by the

recording, chat, or identified primary documentation. Where a name could not be checked against another part of the same recording, it is left unverified rather than guessed. Logistics, introductions, and names of speakers are omitted.

Full supply-chain session: local background, hardware-wallet floor discussion, JFSA Zoom briefing, and a next-step proposal that drew no objection. The business-meeting opening is not given again here. No industry or investor session. Japanese passages mostly frame the English plan; they were not used as a second source of facts. ASR is poor on names, dates, and the hardware-loss number. The stablecoin-issuer gap and the call-data lesson are the clearest policy claims. Do not merge the cross-chain stories into one named incident.

—.

Source clarifications and open checks

Introduction slides 5 and 9 identify FISC, NIST CSF 2.0, SSDF and EU CRA. The caption fragments "Megal link," version "E" and "program 50" remain unconfirmed.

Editorial check: introduction slide 7 reports over US$86 million, with the investigation ongoing. The caption's magnitude and unit are corrected; independent verification of the reported loss remains outside this source check.

Editorial check: the paper dates Bybit to February 2025. Introduction slide 7 gives 13 October for the reported MediaMarkt suspension and 1 January 2027 for the planned Trezor reseller reduction.

Introduction slide 7 describes an LTE/eSIM implant that reads the 24-word recovery phrase from the display. This resolves the device description as a submitted claim; "Eq signatures" for the future RAM point remains unconfirmed.

Editorial check: Resolv, Kelp DAO/LayerZero, and Litecoin are identified by the paper. Kelp DAO and LayerZero form one case; Litecoin is separate. Garbled exit-asset labels remain unconfirmed.

"Beginning of this year" versus "beginning of next year" for public comment. The latter matched the rest of the briefing.